Udyam Digital: data privacy and security note

Accel Business · YTL Hackathon 2026, Track A. Design choices in the prototype, mapped to the Digital Personal Data Protection Act, 2023 (DPDP). All data in the demo is synthetic.

1. Collect only what each step needs (purpose limitation and data minimisation)

STEP	WHAT WE COLLECT	WHY	WHAT WE DO NOT COLLECT
Advisor	Business type, city/PIN, sites, staff count, current setup, needs, budget; GSTIN only if the owner offers it	Choose an eligible bundle and price it	Name, phone, ID numbers, documents
Order	Contact name and mobile (shown masked as ••••••3210)	Resume the order and send updates	Email, address, date of birth
KYC	GST certificate, Udyam certificate, signatory ID, one utility bill	Verify the business before activation	Bank statements, Aadhaar images, extra pages
Booking	Install slot; UPI ID stored masked (•••@bank)	Schedule install and set up autopay	Card numbers, UPI PIN

2. Notice and consent (DPDP s.5, s.6)

- A plain-language consent screen in English or Hindi appears **before** any upload. It says what is collected, why, how long it is kept and the owner's rights.
- Verification consent is required to continue. Marketing on WhatsApp is a **separate, unticked** opt-in.
- Each consent is stored with a version, timestamp, language and purpose flags. The API refuses uploads without it (HTTP 412).

3. The AI never sees documents

- The language model receives only the business profile, with GSTIN masked. KYC images and extracted fields never go to it.
- The LLM cannot set prices. Prices come from the rules engine, and if the explanation mentions a rupee amount that is not in the quote, it is discarded and a template is used.
- Without an API key the advisor runs rule-based, so no data leaves the server.

4. Security safeguards (DPDP s.8(5))

- **Encryption at rest:** uploaded images are encrypted with Fernet (AES-128 + HMAC). The key is kept outside the database (env var or 0600 key file).
- **Masking:** GSTIN (37••••••••7L1ZS), ID numbers, consumer numbers, UPI IDs and mobile numbers are masked in screens, API responses and the audit log.
- **Access:** the owner's case needs order ID + 6-digit code. The back office needs a staff token (SSO and roles in production). Reviewers see only flagged checks.
- **Integrity:** idempotency keys stop duplicate orders and charges on retry. Prices and eligibility are re-checked on the server before an order is created.
- **Audit trail:** every consent, upload, check, review decision and milestone is logged, with identifiers masked.

5. Retention and erasure (DPDP s.8(7))

- Demo: document images are deleted automatically **24 hours** after upload, purged on start-up and on every upload.
- The owner can delete documents at any time from the tracker ("Delete my documents").
- Production: keep the verification **result** and consent record for the contract term plus the period telecom KYC rules require. Delete images once the verification is approved.

6. Owner rights (DPDP s.11 to 13)

- **Access:** the tracker shows the status, checks run and data held for the order.
- **Correction:** failed checks come with a plain fix (for example "upload a bill dated after 2026-04-16"), and the owner can re-upload.
- **Withdrawal and erasure:** one-tap document deletion. Withdrawing consent stops processing.
- **Grievance:** help line and WhatsApp on every tracker page. Escalation goes to a named grievance officer in production.

7. Human in the loop for risky cases

- Automatic approval happens only when every check passes. Registry problems (cancelled GSTIN), name mismatches and unreadable IDs go to a reviewer, never to an automatic rejection.
- Issues the customer can fix (blurry photo, old bill, missing page) go back to the owner with instructions.
- Orders with GST-only products cannot be activated on an inactive GSTIN.

8. Breach handling (DPDP s.8(6))

Breach playbook: contain, rotate the vault key, assess the impact from the audit log, then notify the Data Protection Board and affected owners as the Act requires.

Production gaps we would close: DigiLocker pull instead of photo upload; Aadhaar-based e-sign and DoT-approved subscriber verification for SIMs; PostgreSQL with row-level access; a KMS-managed key; penetration test and DPIA before launch. The 90-day address-proof rule and the 2026-07-15 "today" date come from the case fixture.